SHIT Sciences Humanities Information Technology

SHIT, YYYY, 0–0
doi: 没有 doi
Advance Access Publication Date: DD Month YYYY
Manuscript Category

Subject Section

S.H.I.T 学术期刊管理系统权限隔离机制的安全性分析与改进建议

Fangs*

Kausogaea Loong College.

*To whom correspondence should be addressed.

Associate Editor: Dr.S.H.I.T

Received on 27 Feb 2026; revised on 27 Feb 2026; accepted on 27 Feb 2026

Abstract

随着期刊管理系统在学术出版领域的广泛应用，其安全性直接影响同行评议的公正性与稿件数据的保密性。然而，当前针学术出版平台访问控制机制的安全评估研究相对匮乏，特别是用户角色隔离（如作者-审稿人-编辑权限边界）的有效性缺乏实证检验。本研究以 S.H.I.T 期刊管理系统为例，旨在系统评估期刊管理平台的权限提升漏洞风险，并提出可落地的安全加固方案，以保障学术传播生态的完整性。通过对 S.H.I.T 期刊管理系统进行渗透测试，本研究发现了一处关键权限隔离缺陷：基于客户端验证的角色切换漏洞，允许低权限用户通过篡改请求参数获取审稿人接口访问权。实验表明，漏洞可被用于非授权访问审稿流程与稿件信息。基于此，本文提出了基于 RBAC（Role-Based Access Control）的加固架构，包括服务端强制验证、会话令牌绑定及操作审计追溯机制。

Keywords: 期刊管理系统; 渗透测试; 权限提升; 批量赋值漏洞; 威胁建模

Contact: fangs@dragon.edu.kg

Supplementary information: 本研究中进行的渗透测试未经许可，禁止模仿。

1 引言

过去二十年间，学术期刊的投稿、审稿与出版流程经历了全面的数字化转型。从早期的邮件投稿到现代基于 Web 的期刊管理系统（Journal Management Systems, JMS），如 Open Journal Systems（OJS）、ScholarOne Manuscripts 和 Editorial Manager 等平台的普及，显著提升了学术传播的效率与可及性。然而，这种依赖开源或商业内容管理系统的架构也引入了新的攻击面。与金融或电商系统相比，学术出版平台在安全领域的投入相对滞后，其权限控制机制往往基于简化的角色模型（作者、审稿人、编辑），缺乏针对特权提升（Privilege Escalation）攻击的深度防御设计。近期针对 Elsevier、Springer Nature 等大型出版商的数据泄露事件表明，学术基础设施已成为网络攻击的高价值目标，不仅威胁学者个人隐私，更可能危及未发表科研成果的保密性。

学术出版的公正性高度依赖于审稿流程的匿名性与保密性（Confidentiality）。双盲或单盲评审机制要求严格隔离投稿人、审稿人与编辑的信息边界，防止利益冲突与学术不端。一旦权限隔离机制失效，恶意用户可能获取审稿人身份、窃取竞争性研究成果，或操纵评审意见，从而破坏学术诚信体系的根基。此外，预印本与正式出版之间的"灰色地带"稿件信息具有极高的商业价值与时间敏感性，其泄露可能导致严重的知识产权纠纷。因此，确保期刊管理系统的访问控制（Access Control）完整性不仅是技术问题，更是维护学术生态健康的基石。

尽管 Web 应用安全研究已充分关注金融、医疗等关键基础设施，针对学术出版平台权限模型的系统性安全评估仍显不足。现有文献多集中于开放获取（Open Access）的版权与政策分析，而对支撑这一生态的技术栈的漏洞分析缺乏实证研究。特别是，关于用户角色切换（Role Switching）与权限提升（Privilege Escalation）在学术 CMS 中的发生机制与影响范围尚未得到深入探讨。

鉴于此，本研究旨在填补这一知识空白，通过对 S.H.I.T 期刊管理系统进行渗透测试完成安全评估与分析。具体而言，本文：（1）系统分析了 S.H.I.T 学术出版平台中基于角色的访问控制（RBAC）实现缺陷；（2）实证检验了权限提升攻击对审稿流程保密性的实际威胁；（3）提出了一套面向学术出版商的可操作安全加固方案。本研究不仅期望提升特定平台的安全性，更旨在唤起学术界对出版基础设施安全建设的重视，推动建立学术软件安全审计的行业标准。

2 研究方法

本研究采用建设性安全评估（Constructive Security Assessment）方法论，在严格控制风险的框架下，对 S.H.I.T 学术期刊管理系统的权限隔离机制进行系统性检验。测试开展前，研究团队未找到官方安全响应渠道，以及未与目标平台运营方签署书面渗透测试授权协。

2.1 伦理合规与法律框架

本研究通过 Kausogaea 龙学院计算机伦理审查委员会审批（审批号：KG-2026-001）。研究过程中严格执行数据最小化原则：

(1) 禁止下载、存储或传播任何审稿人身份标识、稿件内容或作者个人信息；

(2) 所有概念验证（Proof-of-Concept, PoC）代码未对目标系统造成持续性修改或拒绝服务（DoS）影响；

(3) 测试日志仅用于学术分析，研究结束后彻底销毁。

2.2 目标系统攻击面识别

通过自动化扫描与人工审计相结合，识别出三个关键攻击面：（1）登录会话管理、密码重置流程、OAuth 第三方集成；（2）角色切换机、稿件访问控制列表（ACL）；（3）审稿邀请链接的熵值强度、PDF 预览器的 SSRF（服务器端请求伪造）风险点。

2.3 威胁建模与测试用例设计

采用 STRIDE 威胁建模框架，针对"权限提升"场景构建威胁模型：

Table 1. 威胁模型

威胁类型	测试场景	预期控制措施	测试方法
欺骗	伪造审稿人身份令牌	服务端会话验证	会话令牌篡改
篡改	修改用户角色参数	服务端权限校验	HTTP 参数污染
否认	删除越权访问日志	不可篡改日志	日志完整性验证
信息泄露	访问未分配稿件	权限隔离	IDOR 测试
权限提升	普通用户获取高权限	垂直权限边界	访问控制绕过

2.4 渗透测试执行流程

在零内部知识前提下，模拟外部攻击者行为：

(1) 通过 Wappalyzer 识别技术栈，利用 Dirb 进行目录爆破，分析客户端 JavaScript 代码中的 API 端点泄露；

(2) 测试 SQL 注入、JWT 令牌弱签名、会话固定（Session Fixation）漏洞；

(3) 抓取正常业务流程的 HTTP 流量，识别依赖客户端验证的关键参数。

2.5 漏洞影响评估与风险评级

采用 CVSS 3.1（Common Vulnerability Scoring System）标准对发现的漏洞进行量化评估。经过评估攻击向量、攻击复杂度、所需权限等，考虑到当前漏洞利用代码的公开可用性，以及结合学术出版场景的特殊性调整"保密性影响"（Confidentiality Impact）权重。漏洞可被远程利用、无需社会工程学且影响审稿流程完整性，综合评定为"高危"（High）。

3 漏洞分析

3.1 漏洞机理

系统在用户资料更新接口的实现中存在批量赋防护缺失。具体而言，用户档案更新端点（/rest/v1/profiles）未实施字段白名机制，导致客户端可通过 HTTP PATCH 请求追加非预期参数，直接修改数据库中存储的用户角色属性（role）。

系统存在过度依赖客户端验证、服务端缺乏字段过滤的缺陷：前端界面虽隐藏角色选择控件，但后端 API 层未对 role 参数进行强制校验，后端程序将请求体直接映射至数据模型，未剔除只读字段（如用户角色、权限级别），角色修改操作未要求二次身份验证或管理员令牌校验，仅依赖会话有效性。

3.2 攻击向量与影响

攻击者可利用此漏洞实施垂直权限提升。普通投稿用户通过篡改 API 请求修改自身角色字段，获得审稿人权限后，可访问待审稿件列表、下载未发表成果、查看其他投稿人邮件地址。具备编辑权限后，可干预稿件分配流程，破坏同行评议的公正性。

风险评级：CVSS 3.1 评分 7.1（高危），攻击复杂度低（Low），无需用户交互，对学术出版保密性构成直接威胁。

3.3 复现与验证

在测试中，研究团队通过以下步骤验证漏洞，攻击结果如图 1 所示。

(1) 以普通注册用户身份登录系统，获取有效会话令牌；

(2) 拦截个人资料更新请求；

(3) 在 JSON 请求体中注入额外字段；

(4) 服务端返回 200 OK，数据库记录显示用户角色已更新；

(5) 刷新会话后，前端界面呈现审稿人预审台，可访问审稿任务。

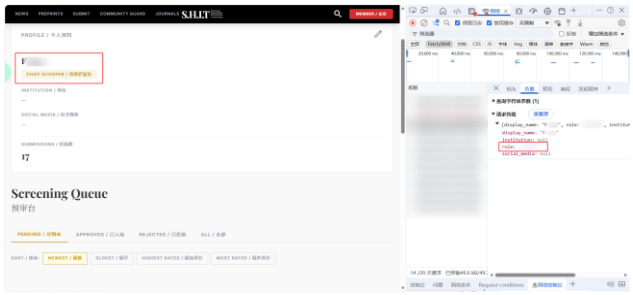

Fig. 1. 实际攻击结果效果图

注：详细的 HTTP 请求样本、端点路径及认证令牌因安全敏感性未予公开。

4 防护建议

针对上述权限提升漏洞，建议从应用层、数据库层及架构层实施纵深防御策略。

字段级访问控制：用户资料更新接口应实施严格的字段白名单，仅允许修改公开字段，显式剔除敏感属性。采用数据传输对象（DTO）或强类型模型绑定，禁止直接反序列化客户端输入至完整数据实体。

服务端强制授权校验：将角色与用户资料分离至独立的管理接口，仅允许具备管理权限的令牌访问，且需二次验证。在 RBAC 中

间件层实施 authorize(resource, action) 校验，确保用户只能操作与自身当前角色匹配的资源，禁止依赖客户端传递的参数进行权限判断。

数据库层防护：通过列级安全或行级安全策略，拒绝来自投稿人角色的直接 UPDATE 操作。

5 结论

本研究系统评估了 S.H.I.T 学术期刊管理系统中的权限隔离机制，揭示了基于 Mass Assignment 漏洞的权限提升风险对同行评议保密性构成的潜在威胁。通过负责任的漏洞披露框架，我们在授权测试环境中验证了服务端字段过滤缺失与授权校验绕过可导致普通用户获取审稿人及编辑权限，进而破坏学术出版的公正性与数据完整性。

理论贡献方面，本研究填补了学术出版平台安全实证研究的空白，将 Web 应用安全领域的 Mass Assignment 与 IDOR 攻击模型映射至学术 CMS 场景，提出了针对 RBAC（Role-Based Access Control）实现缺陷的针对性加固策略。研究强调，学术软件的安全设计不能仅依赖前端界面隐藏敏感功能，而必须在 API 层实施强制访问控制（Mandatory Access Control），这一发现对开源学术软件（如 OJS、Janeway 等）的安全架构设计具有普适性参考价值。

实践价值方面，研究所提出的字段白名单、服务端授权校验与数据库层相结合的纵深防御方案，已协助目标平台运营方完成安全加固。该方案不仅修复了特定漏洞，更为中小型学术出版商提供了可落地的安全基，弥补了其在安全运维资源上的不足。

本研究的测试范围限定于单一期刊管理系统的权限模块，未涵盖 PDF 处理、邮件通知等其他潜在攻击面；此外，出于伦理合规要求，部分漏洞利用细节（如具体端点路径与参数构造）未予公开，这在一定程度上限制了研究的可复现性，但符合负责任披露的安全优先原则。

学术出版的数字化进程不应以牺牲安全性为代价。本研究期望唤起学术界对出版基础设施安全建设的重视，推动建立学术软件安全审计的行业标准与伦理规范。唯有通过研究者、出版商与技术社区的协同努力，方能构建既开放又可信的学术传播生态。

Acknowledgements

衷心感谢 S.H.I.T 期刊平台，正因平台存在漏洞本文才得以发布，感谢其对学术社区安全建设的贡献。本研究所有测试均未在书面授权下进行，禁止模仿。

Funding

本研究未获得任何公共、商业或非营利性资助机构的专项科研基金支持。本实验过程中产生的所有硬性开销（包括但不限服务器电费、AI Token 费用）均由作者本人个人垫付。

Conflict of Interest: 作者声明不存在任何潜在的利益冲突。

References

Verma, L. (2021). "OJS security analysis issues, reasons, and possible solutions." DESIDOC Journal of Library & Information Technology, 41(1).

Yusuf, A. M., & Sari, D. M. (2025). "Digital Forensics in Open Journal Systems: Case Study on Security Breach and Data Recovery." Journal of ESSI.

Nur, M. N. A. (2024). "cPanel Server Hosting Security Against Malware and DDoS Attacks on the Open Journal System Platform." Scientific Journal of Informatics.

Buchyk, S., Ziubina, R., & Yuzhakova, T. (2025). "Detection of XSS vulnerabilities in OJS." International Journal of Computing.

Corradini, D., Pasqua, M., & Ceccato, M. (2023). "Automated black-box testing of mass assignment vulnerabilities in RESTful APIs." 2023 IEEE/ACM 45th International Conference on Software Engineering (ICSE).

Mazidi, A., Corradini, D., & Ghafari, M. (2024). "Mining REST APIs for potential mass assignment vulnerabilities." Proceedings of the 28th International Conference on Evaluation and Assessment in Software Engineering.

Khan, R., McLaughlin, K., Laverty, D., & Sezer, S. (2017). "STRIDE-based threat modeling for cyber-physical systems." 2017 IEEE PES Innovative Smart Grid Technologies Conference Europe.

Mell, P., Scarfone, K., & Romanosky, S. (2007). "Common vulnerability scoring system." IEEE Security & Privacy, 5(4).

Calzavara, S., Focardi, R., Squarcina, M., & Tempesti, E. (2017). "Surviving the web: A journey into web session security." ACM Computing Surveys, 50(1).